

MODULE 3.1: ETHICAL HACKING, THREATS & INFORMATION ASSURANCE

Contents

1. Ethical Hacking	1
Ethical vs Unethical Hacking.....	1
Phases of Ethical Hacking.....	3
2. Threat.....	3
Types of Threats	4
Threat Actors & Their Motives	6
Common Attack Vectors.....	7
Attack Vector Categories.....	8
3. Information Assurance (IA)	8
AAA (Authentication, Authorization, Accounting).....	8
Additional IA Concepts	9
Security Controls	9
4. Threat Modelling.....	10
Threat Identification & Prioritization.....	11
Example: Web Application Threat Model	11

Ethical Hacking

- Ethical hacking is the authorized process of identifying vulnerabilities in systems, networks, and applications using the same techniques as malicious hackers, but with legal permission.
- Its purpose is to strengthen security, prevent breaches, and improve an organization's defense posture.

Need for Ethical Hacking in Organizations

- Helps detect vulnerabilities before attackers exploit them
- Validates security controls and compliance requirements
- Protects sensitive data (financial, customer, operational)
- Reduces risk of cyberattacks, downtime, financial loss
- Ensures security of new applications, infrastructure, cloud systems
- Supports incident response planning and risk management

Organizations basically hire ethical hackers to “hack themselves first” before real attackers do.

Ethical vs Unethical Hacking

1. Ethical Hacking (White Hat Hacking): Ethical hacking is **authorized, legal, and goal-driven towards security improvement**. Ethical hackers are employed by organizations to test systems, identify vulnerabilities, and strengthen defenses. **Key Characteristics**

- **Permission-based:** Conducted with written approval and defined scope.
- **Legal:** All activities are compliant with laws and policies.
- **Goal:** Improve security, prevent attacks, and protect data.
- **Transparent process:** Findings are documented and shared with the organization.
- **Controlled techniques:** Uses hacking tools and methods without causing harm.

- **Follows rules of engagement:** Includes NDAs, scope boundaries, timelines, and reporting standards.

Typical Outputs

- Vulnerability reports
- Risk ratings
- Recommendations for mitigation
- Proof-of-concept demonstrations

Examples

- Penetration testing
- Security audits
- Vulnerability assessments
- Red team assessments

2. Unethical Hacking (Black Hat Hacking): Unethical hacking is **unauthorized, malicious, and illegal**. Black-hat hackers break into systems for personal gain, disruption, or exploitation. **Key Characteristics**

- **No permission:** Accessing systems without authorization.
- **Illegal:** Violates cyber laws and can lead to criminal charges.
- **Goal:** Steal data, cause damage, earn money, or exploit victims.
- **Malicious intent:** Activities focus on exploitation and harm.
- **Hide activities:** Delete logs, use anonymity tools, and avoid detection.
- **No reporting:** Never disclose vulnerabilities to the organization.

Typical Actions

- Deploy malware (ransomware, trojans, spyware)
- Data theft (personal info, financial data, credentials)
- Server compromise and website defacement
- Selling access on the dark web
- Social engineering for fraud

Examples

- Hacking bank accounts
- Stealing credit card data
- Breaking into corporate servers
- Unauthorized scanning or exploitation
- Taking systems hostage for ransom

3. Grey Hat Hacking (Middle Ground) Grey-hat hackers operate **without permission**, but **without malicious intent**. They may discover vulnerabilities and inform the organization, but the initial act is still illegal. **Key Characteristics**

- No permission initially
- No intention to harm
- May report vulnerabilities after discovering them
- Legally questionable, ethically mixed

Example: A person finds a website vulnerability, exploits it to prove a point, and emails the admin about the issue.

Feature	Ethical Hacking (White Hat)	Unethical Hacking (Black Hat)
Authorization	Always authorized	Never authorized
Legality	Legal and regulated	Illegal and criminal
Intent	Security improvement	Damage, theft, profit
Outcome	Reports + fixes issues	Exploits vulnerabilities
Transparency	Fully documented	Hidden and deceptive
Impact	Reduces risk	Increases risk and harm

Phases of Ethical Hacking

1. Reconnaissance

- The information-gathering phase.
- The hacker collects data about the target using passive and active methods.
- Examples: whois lookup, Google dorking, social engineering, scanning IP ranges.
- Goal: Understand the target's footprint, technologies, people, and attack surface.

2. Scanning & Enumeration

- Scanning identifies open ports, services, and vulnerabilities using tools like Nmap.
- Enumeration extracts detailed information from those services (users, shares, SNMP data).
- Goal: Map the target system more deeply and identify potential entry points.

3. Gaining Access

- Attempting to exploit vulnerabilities found earlier to enter the system.
- Methods: password cracking, exploitation, SQL injection, buffer overflows.
- Goal: Achieve initial foothold or system compromise.

4. Maintaining Access

- After entry, the hacker ensures continued control using:
 - Backdoors
 - Rootkits
 - Persistent accounts or scheduled tasks
- Goal: Stay in the system for extended analysis or deeper exploitation.
- Ethical hackers do it only to test how attackers could persist.

5. Covering Tracks

- Attackers hide their activities by removing logs, clearing command histories, or using stealth techniques.
- Ethical hackers **never** erase real logs—they simulate or demonstrate how an attacker could hide.
- Goal: Show how attackers avoid detection and help organizations improve monitoring.

Threat

1. Threat, Vulnerability, Risk

Threat

- A potential event or action that can exploit a vulnerability and cause damage to an information system or organization.
- Threats can be intentional (hackers) or unintentional (employee mistakes, hardware failure).

Vulnerability

- A weakness, flaw, or misconfiguration in systems, applications, networks, or human processes that can be exploited by a threat.
- Examples: Unpatched software, weak passwords, open ports, unsecured APIs.

Risk

- The probability that a threat will exploit a vulnerability, multiplied by the impact it would cause. Risk depends on:
 - Likelihood of attack
 - Existing vulnerabilities
 - Value and sensitivity of assets
 - Potential damage
- $\text{Risk} = \text{Threat} \times \text{Vulnerability} \times \text{Impact}$



Types of Threats

1. **Internal Threats:** come from individuals who *already have legitimate access* to the organization. These threats are extremely dangerous because insiders know systems, processes, and security weaknesses. **Examples:**
 - Employees leaking data
 - Misuse of privileges
 - Accidental deletion or misconfiguration
 - Contractors accessing sensitive systems
 - Disgruntled staff sabotaging systems

Why internal threats are dangerous:

- Hard to detect
- Have authorized access
- Know the network layout and data locations
- Insider attacks often bypass perimeter security

2. **External Threats:** These originate from outside the organization. Attackers attempt to break in through exposed services, weak controls, or social engineering. **Examples:**

- Hackers, cybercriminals, hacktivists
- Ransomware groups
- Competitors
- Nation-state threat actors
- Botnets attempting DDoS
- External phishing attacks

External threats usually attempt:

- Network intrusions
- Exploit scanning
- Malware delivery
- Social engineering
- Wi-Fi attacks
- Website exploitation

3. **Network-based Threats:** These target the **network layer** or communication channels.

Examples:

- **DoS/DDoS:** Flooding targets with traffic to take services offline
- **MITM attacks:** Intercepting communication between two parties
- **ARP spoofing:** Redirecting traffic on a LAN
- **DNS spoofing/poisoning:** Redirecting users to malicious sites
- **Packet sniffing:** Capturing sensitive data in transit
- **Rogue Access Points:** Fake Wi-Fi networks used for credential theft

These attacks aim to disrupt availability, hijack sessions, or steal sensitive traffic.

4. **Host-based Threats:** These target **individual devices** like servers, desktops, mobiles. **Examples:**

- **Malware** (virus, trojan, worm, spyware, ransomware)
- **Unauthorized access** using weak passwords
- **Privilege escalation** on Windows/Linux
- **Rootkits** for hidden persistent access
- **Keyloggers** capturing credentials
- **Misconfigurations** (open shares, insecure services)

Host-based threats affect confidentiality, integrity, and availability at the device level.

5. **Application-based Threats:** These target **web apps, APIs, and software**. **Examples:**

- **SQL Injection:** Attacker manipulates database queries
- **XSS:** Attacker injects malicious scripts
- **CSRF:** Forces user to perform actions without consent
- **Broken authentication:** Weak login systems
- **Insecure APIs:** Exposed endpoints allow data theft
- **Buffer overflow:** Writing more data than memory can handle
- **Insecure session management:** Session hijacking

Application threats arise due to coding flaws, insecure logic, or weak backend protection.

6. **Insider Threats:** Insider threats come from people *within* the organization who have legitimate access to systems. These threats are extremely critical because insiders bypass many security controls. **Types of Insider Threats**

a. **Malicious Insider:**

- Purposefully causes harm
- Motivated by revenge, profit, or ideology
- Steals data, deletes files, disrupts operations

b. **Negligent Insider:**

- Makes accidental mistakes
- Common examples:
 - Clicking phishing links
 - Using weak passwords
 - Misconfiguring systems
 - Losing company devices

c. **Compromised Insider:**

- A legitimate user whose account or device has been taken over by attackers
- Example: Phishing compromise of an employee's email or VPN access

Typical insider attacks:

- Data theft (customer records, financial data)
- Intellectual property leakage
- Privilege misuse
- Unauthorized access or modifications
- Sabotage of systems

Why insider threats are dangerous:

- Hard to detect
- Often appear as “normal” user activity
- High access privileges
- Trusted by the organization

7. Physical & Human Threats (More Detailed)

- **Physical Threats:** Threats that involve physical damage or unauthorized access to infrastructure. **Examples:**
 - Theft or loss of laptops, hard drives
 - Fire, flood, electrical failure
 - Break-ins or unauthorized room access
 - Damaging servers or network equipment
 - Installing rogue hardware (USB keylogger, malicious access point)
- **Human Threats:** Caused by human actions — intentional or unintentional. Human threats are the **biggest cause of security breaches** because humans are the weakest link.
 - **Intentional (malicious):**
 - Social engineering
 - Identity theft
 - Blackmail or coercion
 - Impersonation
 - **Unintentional (mistakes):**
 - Misconfiguring servers
 - Using weak passwords
 - Sharing sensitive information accidentally
 - Falling for phishing scams

Threat Actors & Their Motives

Threat actors are individuals or groups who carry out cyberattacks for different purposes. Each type has its own goals, skill levels, and methods.

1. **Cybercriminals:** They attack mainly for **financial gain**. Their activities include ransomware, stealing credit card data, phishing, and selling stolen information. Their goal is profit.
2. **Hacktivists:** They attack organizations to **promote political or social causes**. Their motive is not money but protest, awareness, or ideology. They often deface websites or leak data.
3. **Nation-State Attackers:** These are government-backed groups focused on **espionage, intelligence gathering, and cyberwarfare**. They target defense systems, critical infrastructure, and government networks.
4. **Insiders:** Employees or contractors who misuse their access — intentionally or accidentally. Motives include **revenge, greed, negligence, or being compromised** by external attackers.

5. **Script Kiddies:** Beginners who use ready-made tools without deep knowledge. Their motive is usually **fun, curiosity, or wanting attention**.
6. **Competitors:** Attack to gain **business advantages**, such as stealing trade secrets, customer data, or strategies.
7. **Terrorist Groups:** Use cyberattacks to **cause disruption, spread fear, or damage essential services**.

Common Attack Vectors

1. Network Attacks (DoS, DDoS, MITM)

- Network attacks target communication channels and network services.
- A DoS (Denial of Service) attack overloads a system with traffic from a single source to make it unavailable.
- A DDoS (Distributed DoS) attack does the same but using multiple compromised devices (botnets), making it harder to block.
- In a MITM (Man-in-the-Middle) attack, the attacker secretly intercepts or alters communication between two parties, stealing data or injecting malicious content.

2. Application Attacks (SQLi, XSS, CSRF)

- Application attacks target vulnerabilities in websites or software.
- SQL Injection allows attackers to manipulate database queries to access or modify sensitive data.
- XSS (Cross-Site Scripting) injects malicious scripts into web pages to steal cookies or session data from users.
- CSRF (Cross-Site Request Forgery) tricks users into performing actions they did not intend, like changing passwords or transferring money, by misusing their active session.

3. Wireless Attacks (WEP/WPA Cracking, Evil Twin)

- Wireless attacks exploit weaknesses in Wi-Fi networks.
- WEP/WPA cracking involves breaking weak or outdated Wi-Fi encryption keys to gain access to the network.
- In an Evil Twin attack, the attacker creates a fake Wi-Fi network that looks legitimate; when users connect, their credentials and data are captured.

4. Social Engineering Vectors

- Social engineering attacks exploit human psychology rather than technical flaws.
- Attackers use methods like phishing emails, fake calls, impersonation, and malicious links to trick users into revealing information, clicking harmful links, or giving access.
- These attacks succeed by manipulating trust, fear, or urgency.

5. Physical Breaches

- Physical breaches involve unauthorized access to buildings, server rooms, or devices.
- Examples include tailgating into secure areas, stealing laptops, inserting malicious USB drives, or tampering with hardware.
- This bypasses digital security entirely because the attacker has direct physical control over systems.

Attack Vector Categories

1. **Web-Based Attack Vectors:** These include attacks that target websites and web applications such as SQL Injection, XSS, CSRF, directory traversal, and session hijacking. They exploit coding flaws or weak security configurations in web systems.
2. **Email-Based Attack Vectors:** Email is one of the most common attack channels. Attackers send phishing emails, malicious attachments, fake invoices, or links that deliver malware or steal credentials. Business Email Compromise (BEC) also falls under this category.
3. **Removable Media Attack Vectors:** Removable devices like USB drives can carry malware that automatically executes when plugged in. Attackers may leave infected USBs in public areas hoping employees insert them into office computers, allowing malware to spread or data to be stolen.
4. **Supply Chain Attack Vectors:** In supply chain attacks, the attacker targets a third-party vendor or service provider to infiltrate the main organization. This can include compromised software updates, infected hardware components, or vendor account takeover. It's dangerous because organizations trust their suppliers.
5. **Cloud and IoT Attack Vectors:** Cloud-based attacks exploit misconfigured buckets, weak access control, insecure APIs, or shared resources in multi-tenant environments. IoT devices are often vulnerable due to default passwords, outdated firmware, and lack of encryption. Attackers use these weaknesses to gain entry, create botnets, or steal data.

Information Assurance (IA)

IA comprises measures that protect and defend information and information systems by ensuring their **availability, integrity, authentication, confidentiality, and non-repudiation (AIACN)**.

Pillar	Explanation
Availability	Information and systems are accessible and functional when authorized users need them.
Integrity	Information is accurate, complete, and protected from unauthorized modification or destruction.
Authentication	Verifying the identity of users or devices (who you are).
Confidentiality	Preventing the unauthorized disclosure of information.
Non-repudiation	Providing proof of the origin and integrity of data, preventing denial.

AAA (Authentication, Authorization, Accounting)

1. Authentication

- Authentication is the process of **verifying the identity** of a user, device, or system before granting access. It ensures that the person or system trying to log in is who they claim to be.
- Common authentication methods include passwords, biometrics, OTPs, smart cards, and multi-factor authentication.
- Without proper authentication, attackers can easily impersonate legitimate users.

2. Authorization

- Authorization determines **what actions or resources an authenticated user is allowed to access**.
- Once the user is verified, the system checks their permissions — for example, whether they can view, edit, delete, or manage certain data.

- Authorization is typically enforced through access control mechanisms like Role-Based Access
- Control (RBAC) or policy-based controls.

3. Accounting

- Accounting (or Auditing) refers to **tracking and recording user activities** within the system.
- It includes logging login attempts, resource usage, file access, configuration changes, and any unusual activities.
- Accounting helps in detecting misuse, investigating incidents, meeting compliance requirements, and maintaining accountability.

Additional IA Concepts

1. Non-Repudiation

- Non-repudiation ensures that a user **cannot deny performing an action** such as sending a message, making a transaction, or approving a request.
- This is achieved through mechanisms like digital signatures, secure logs, timestamps, and audit trails.
- It is essential in legal, financial, and e-commerce systems where proof of action is required.

2. Assurance Levels & Mechanisms

- Assurance refers to the **confidence level** that security measures are working as intended.
- Higher assurance levels mean stronger, more reliable controls.
- Mechanisms used to provide assurance include security testing, code reviews, penetration testing, configuration management, audits, and formal verification.
- Assurance focuses on proving that systems are protected, trustworthy, and functioning securely under expected conditions.

Security Controls

1. Preventive Controls: These controls are designed to **stop** an incident or policy violation from occurring in the first place. They aim to reduce the **likelihood** of a successful attack.

- **Goal:** To prevent unauthorized actions and protect resources.
- **Action:** Acts **before** an event.
- **Examples:**
 - **Firewalls and Access Control Lists (ACLs):** Block unauthorized network traffic.
 - **Strong Passwords and Multi-Factor Authentication (MFA):** Prevent unauthorized access to accounts.
 - **Encryption:** Protects data at rest and in transit from being read if intercepted.
 - **Security Awareness Training:** Prevents human error and social engineering attacks.
 - **Intrusion Prevention Systems (IPS):** Actively block detected malicious traffic.

2. Detective Controls: These controls are designed to **identify** an incident, either while it is in progress or immediately after it has occurred. They alert administrators to a breach or policy violation.

- **Goal:** To discover and document a security event.
- **Action:** Acts **during or after** an event.
- **Examples:**
 - **Intrusion Detection Systems (IDS):** Monitor network traffic for suspicious activity and alert the team.

- **Audit Logs and System Logs:** Record system and user activity for review.
- **Security Information and Event Management (SIEM):** Aggregates and analyzes log data from multiple sources to spot anomalies.
- **CCTV Cameras and Motion Detectors:** Monitor physical access.
- **Checksums/Hashing:** Verify the integrity of files after transmission.

3. **Corrective Controls:** These controls are designed to **lessen the damage** caused by a security incident and restore the system or business process back to a secure, operational state.

- **Goal:** To minimize the impact, repair the damage, and recover systems.
- **Action:** Acts **after** an event has been detected.
- **Examples:**
 - **Data Backups and Restoration:** Used to recover lost or corrupted data.
 - **Patching and Vulnerability Management:** Applying updates to fix the vulnerability that was exploited.
 - **Anti-virus/Anti-malware Software:** Used to quarantine and remove malicious code after detection.
 - **Incident Response Plans:** The documented procedures followed to manage and resolve a security breach.

Threat Modelling

- Threat modelling is the structured process of identifying potential threats, vulnerabilities, and attack scenarios *before* they cause damage.
- Its purpose is to understand how an attacker might compromise a system and then design appropriate security measures to reduce risks. Purpose:
 - Helps detect weaknesses early in the development lifecycle
 - Reduces future security costs by preventing design flaws
 - Ensures systems are built with security-by-design principles
 - Prioritizes high-risk areas that need immediate protection
 - Helps meet compliance and industry standards
- Overall, threat modelling gives a clear picture of “what can go wrong” and how to prevent it.

Approaches to Threat Modelling

1. **STRIDE Model:** STRIDE is a framework used to categorize threats. It stands for:

- **S – Spoofing** (pretending to be someone else)
- **T – Tampering** (modifying data or systems)
- **R – Repudiation** (denying actions performed)
- **I – Information Disclosure** (leaking sensitive data)
- **D – Denial of Service (DoS)** (making services unavailable)
- **E – Elevation of Privilege** (gaining unauthorized higher access)

STRIDE helps developers systematically check each component of a system for these threat categories.

2. **DREAD Model:** DREAD is a scoring system used to measure the **severity** of threats. It stands for:

- **D – Damage Potential**
- **R – Reproducibility** (how easily it can be repeated)
- **E – Exploitability** (how easy to exploit)

- **A – Affected Users**
- **D – Discoverability** (how easy to discover the flaw)

Each factor is rated, and the total gives a priority score. Higher scores = higher risk.

3. **Attack Trees:** Attack Trees visually represent how an attacker can achieve a goal.
 - The root node is the attacker's main goal (e.g., steal data).
 - Branches represent different steps, techniques, or sub-attacks that lead to the goal.
 - Attack trees help understand all possible attack paths and select the most effective defensive controls.

Threat Identification & Prioritization

1. **Identify Assets & Entry Points:** Identify what needs protection (data, servers, APIs, user accounts) and the possible entry points attackers can use (login pages, APIs, network ports, Wi-Fi, physical access). This step defines the attack surface.
2. **Identify Threats & Vulnerabilities:** Analyze how attackers can exploit weaknesses. Example: Unpatched software, weak authentication, insecure APIs, sensitive data exposed in URLs, misconfigured servers.
3. **Assess Impact & Likelihood:** Every threat is evaluated based on:
 - **Impact** → How bad the damage would be
 - **Likelihood** → How likely the threat is to occur
 This helps categorize threats as high, medium, or low risk.
4. **Mitigation Strategies & Controls:** For each identified threat, decide how to reduce or eliminate it. Common mitigation techniques include:
 - Patching vulnerabilities
 - Strengthening authentication
 - Encryption
 - Input validation
 - Network segmentation
 - Monitoring and logging
 - Least privilege access

Example: Web Application Threat Model

Step 1 Identify Assets: User accounts, login credentials, database records, API endpoints, admin panel, payment details.

Step 2 Identify Entry Points: Login page, search box, forms, API endpoints, cookies, public URLs.

Step 3 Identify Threats (Using STRIDE)

- Spoofing → Fake login attempt using stolen credentials
- Tampering → SQL injection to modify database
- Repudiation → User denies performing an action
- Information Disclosure → Sensitive info leaked due to XSS
- DoS → Flooding server with traffic
- Elevation of Privilege → Attacker escalates from normal user to admin

Step 4 Prioritize Using DREAD: SQL injection may score highest due to high damage, easy reproducibility, and high exploitability.

Step 5 Apply Mitigation Controls

- Input validation and parameterized queries
- Strong authentication and session management

- Logging and non-repudiation controls
- Rate limiting to prevent DoS
- OWASP security practices

This structured approach helps secure the application before deployment.